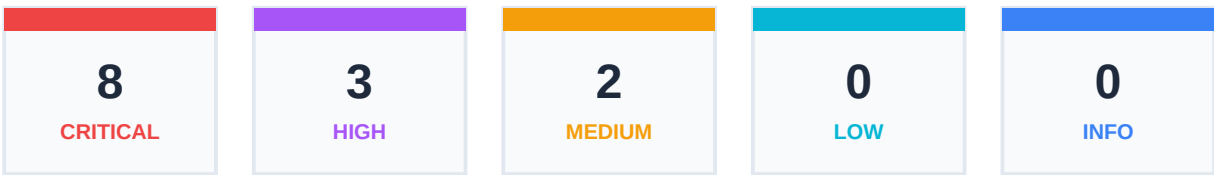


Sudoers Security Audit

CONFIDENTIAL SECURITY REPORT

Target Host: DESKTOP-1H3ADSE
Sudo Version: Unknown
Generated On: 2026-06-13 17:59:17 CEST

Findings Summary



Detailed Audit Findings

SUDO-DEF-001: Missing secure_path Configuration

HIGH

Location: test_policy.json

The global 'secure_path' default is not defined. Sudo will run commands using the calling user's PATH variable, which can lead to local command hijacking/privilege escalation if the user's PATH contains writable directories.

REMEDIATION:

Add 'Defaults secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"' to the sudoers file.

Add 'Defaults secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin"' to the sudoers file.

SUDO-DEF-003: Missing or Disabled use_pty

MEDIUM

Location: test_policy.json

The 'use_pty' flag is not enabled globally. Without a pseudo-terminal (PTY) allocation, processes run via sudo can write to the terminal's input buffer using TIOCSTI ioctl, enabling terminal hijacking and command injection back into the user's shell.

REMEDIATION:

Add 'Defaults use_pty' globally to the sudoers file.

Add 'Defaults use_pty' globally to the sudoers file.

SUDO-DEF-004: Dangerous Environment Variables Preserved (env_keep)**CRITICAL**

Location: test_policy.json

The policy explicitly preserves dangerous environment variables in env_keep: LD_PRELOAD, PYTHONPATH. This can allow local users to inject code into elevated processes (e.g. via dynamic linker hijack LD_PRELOAD, or PYTHONPATH/PERL5LIB library paths).

REMEDIATION:

Remove dynamic library path and interpreter path environment variables from 'env_keep' additions in sudoers Defaults.

SUDO-DEF-005: visiblepw Flag Enabled**HIGH**

Location: test_policy.json

The 'visiblepw' option is enabled globally. This forces sudo to print the password in cleartext if prompting on a terminal, exposing it to shoulder surfing or screen logs.

REMEDIATION:

Remove 'Defaults visiblepw' or explicitly set 'Defaults !visiblepw'.

```
Remove 'Defaults visiblepw' or explicitly set 'Defaults !visiblepw'.
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: find (file-read)**CRITICAL**

User/Group: bob | Command: /usr/bin/find | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/find' via sudo without a password (NOPASSWD) using the 'file-read' bypass method. This enables instant root privilege escalation.

GTFObins Context: This uses `cat` to actually read the file, but since permissions are not dropped, it's executed with the same privileges as `find`.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
find /path/to/input-file -exec cat {} \;
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: find (file-write)**CRITICAL**

User/Group: bob | Command: /usr/bin/find | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/find' via sudo without a password (NOPASSWD) using the 'file-write' bypass method. This enables instant root privilege escalation.

GTFObins Context: `DATA` is a format string, it supports some escape sequences.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
find / -fprintf /path/to/output-file DATA -quit
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: find (shell)**CRITICAL**

User/Group: bob | Command: /usr/bin/find | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/find' via sudo without a password (NOPASSWD) using the 'shell' bypass method. This enables instant root privilege escalation.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
find . -exec /bin/sh \; -quit
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: awk (file-read)**CRITICAL**

User/Group: bob | Command: /usr/bin/awk | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/awk' via sudo without a password (NOPASSWD) using the 'file-read' bypass method. This enables instant root privilege escalation.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
mawk '//' /path/to/input-file
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: awk (file-write)**CRITICAL**

User/Group: bob | Command: /usr/bin/awk | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/awk' via sudo without a password (NOPASSWD) using the 'file-write' bypass method. This enables instant root privilege escalation.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
mawk 'BEGIN { print "DATA" > "/path/to/output-file" }'
```

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: awk (shell)**CRITICAL**

User/Group: bob | Command: /usr/bin/awk | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/awk' via sudo without a password (NOPASSWD) using the 'shell' bypass method. This enables instant root privilege escalation.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
mawk 'BEGIN {system("/bin/sh")}'
```

SUDO-CMD-004: Wildcard in Command Definition

MEDIUM

User/Group: bob | Command: /usr/bin/cat /var/log/* | Location: test_policy.json

The command '/usr/bin/cat /var/log/*' allowed for user(s) [bob] contains wildcards. Arguments matching wildcards in sudoers can often be bypassed using directory traversals (e.g. '/var/log/../../etc/shadow') or injection flags.

REMEDIATION:

Avoid wildcards in command paths. Use specific paths or write wrapper scripts that sanitize inputs before executing commands.

SUDO-GTFO-002: Passwordless Dangerous Sudo Binary allowed: cat (file-read)

CRITICAL

User/Group: bob | Command: /usr/bin/cat /var/log/* | Location: test_policy.json

The user(s) [bob] can run '/usr/bin/cat /var/log/*' via sudo without a password (NOPASSWD) using the 'file-read' bypass method. This enables instant root privilege escalation.

REMEDIATION:

Remove this binary from sudoers or replace it with a wrapper script.

```
cat /path/to/input-file
```

SUDO-CMD-001: Negated Command Policy

HIGH

User/Group: bob | Command: /usr/bin/passwd | Location: test_policy.json

The policy contains a negated command '/usr/bin/passwd' for user(s) [bob]. Sudo command negation is easily bypassed by symlinking the binary, copying it to another location, or executing it with slightly different paths/arguments.

REMEDIATION:

Avoid using negated commands (!) to enforce restrictions. Instead, use a strict allowlist of permitted commands.